Case 01 – Kongtuke Traffic Analysis Report

Oct 2, 2026 · @Srivatsan Kumar

Case overview

Host 10.9.11.135 (user gmcdowell) was likely infected after visiting a compromised website, then contacted several attacker-controlled domains over about 20 minutes. Findings marked "suspected" still need confirmation.

Item	Value
Exercise	2026-09-11 Traffic Analysis Exercise: Kongtuke Rebuke (malware-traffic-analysis.net)
PCAP	2026-09-11-traffic-analysis-exercise.pcap (renamed case01.pcap), 57 MB
Capture start	Sep 11, 2026 20:05:55 UTC
Capture length	about 1,256 seconds (about 21 minutes)
Victim IP	10.9.11.135
Victim user	gmcdowell (from Kerberos)
Victim hostname	Open: not found yet
AD domain	overhands.org
Domain controller	10.9.11.2 (WIN-GTWXC9UYSE4)
Tools	Wireshark, Tshark, Suricata, Snort

Steps 1–3: Lab setup

All analysis ran in an isolated Ubuntu VM with no shared folders, since the PCAP contains real malware traffic.

```
sudo apt install -y wireshark tshark suricata snort p7zip-full
mkdir -p ~/netforensics/{pcaps,cases,rules,scripts,logs}
cd ~/netforensics && git init
echo "pcaps/" >> .gitignore
```

Tool	Version	Used for
Wireshark / Tshark	Ubuntu package	Packet analysis
Suricata	7.0.3	Rule testing
Snort	2.x	Rule testing

Issue fixed: the project folder was first created at /netforensics as root, which blocked writes. It was moved to ~/netforensics and ownership changed with chown.

Steps 4–5: Getting the PCAP

The PCAP came from malware-traffic-analysis.net and was extracted with the site's date-based password (infected_YYYYMMDD).

```
mv ~/Downloads/*.zip ~/netforensics/pcaps/
cd ~/netforensics/pcaps
7z x 2026-09-11-traffic-analysis-exercise.pcap.zip -pinfected_20260911
mv 2026-09-11-traffic-analysis-exercise.pcap case01.pcap
mkdir -p ~/netforensics/cases/case01
```

Issue fixed: the plain password "infected" failed and left a 0-byte file. The site's About page gave the new scheme, infected_ plus the post date.

Steps 6–7: Triage and victim identification

Triage showed one internal host, 10.9.11.135, talking to several unknown external IPs; Kerberos and NBNS identified the user and domain.

```
P=~/netforensics/pcaps/case01.pcap
capinfos $P
tshark -r $P -qz io,phs 2>/dev/null
tshark -r $P -qz conv,ip 2>/dev/null | head -30
tshark -r $P -Y "nbns" -T fields -e ip.src -e nbns.name 2>/dev/null
tshark -r $P -Y "kerberos.CNameString" -T fields -e ip.src -e
kerberos.CNameString 2>/dev/null
```

Top conversations (victim 10.9.11.135):

External IP	Received by victim	Sent by victim	Start (s)	Duration (s)	Note
104.16.212.131	36 MB	1,871 kB	51.6	3.8	Large fast download
172.67.180.55	7,495 kB	277 kB	42.6	733.6	Open
86.106.87.134	153 kB	4,825 kB	61.7	1,194.9	Victim uploads more than it downloads
10.9.11.2	203 kB	231 kB	0.0	1,256.1	Domain controller
62.3.53.87	6.8 kB	118 kB	981.5	258.7	Starts late

The tshark CLDAP "Dissector bug" warnings are a tool parsing limit, not attack traffic; 2>/dev/null hides them.

Steps 8–12: Protocol analysis

DNS and TLS SNI exposed the suspicious domains; the main C2 candidate, 86.106.87.134, uses plain HTTP on port 80. Credential leakage has not been checked yet.

Step	What was checked	Command / filter	Finding
8. DNS	Domains the victim looked up	dns.flags.response==0	quadcinema[.]com then aatthews[.]cfd at 20:05:55; later random-looking domains (bert-hits, comonto-rsr, fif-lost, mom-nower, globalcert8618, winrun2915)

Step	What was checked	Command / filter	Finding
9. HTTP	Downloads and check-ins	http.request	Traffic to 86.106.87.134 is HTTP on port 80; request details open
10. TLS	Encrypted destinations via SNI	tls.handshake.type==1	aatthews[.]cfd → 172.67.205.86, logincrypt8338[.]com → 172.67.214.168, jaw.xos-aploq[.]com → 104.21.34.58
11. C2 beaconing	Repeated connections to one IP	Statistics → Conversations; SYN-only filter	86.106.87.134: about 20 min, about 4.8 MB sent out; interval open
12. Credentials	Plain-text logins	ftp || smtp || http.request.method=="POST"	Open

Normal traffic excluded: Microsoft (login.live.com, microsoftonline.com, bing.com), Google analytics, code.jquery.com, and Windows AD traffic to 10.9.11.2 (Kerberos, LDAP, SMB, wpad).

Step 13: File extraction and hashes

HTTP objects were exported and hashed; the hash values still need to be added to the IOC table and checked on VirusTotal.

```
cd ~/netforensics/pcaps
mkdir objects
tshark -r case01.pcap --export-objects http,objects
sha256sum objects/* > hashes.txt
```

Extracted files are real malware: never open or run them, and never commit them to GitHub.

Step 14: Indicators of compromise

Ten suspicious domains and five suspicious IPs found so far; file hashes are still open. Indicators are defanged ([.]) so they are not clickable.

Type	Indicator	Resolved IP	First seen (UTC)	Evidence	Status
Domain	quadcinema[.]com	Open	20:05:55	DNS frame 1	Suspected compromised site
Domain	aatthews[.]cfd	172.67.205.86	20:05:56	DNS frame 41, TLS frame 53	Suspected injected script host
Domain	logincrypt8338[.]com	172.67.214.168	Open	TLS frame 5224	Suspected
Domain	jaw.xos-aploq[.]com	104.21.34.58	Open	TLS frame 14279	Suspected
Domain	know.mom-nower[.]com	Open	20:18:59	DNS frame 71423	Suspected C2
Domain	globalcert8618[.]net	Open	20:19:08	DNS frame 71436	Suspected C2
Domain	winrun2915[.]com	Open	Open	DNS	Suspected C2
Domain	now / firt / start.comonto-rsr[.]com	Open	20:22:17	DNS frame 72431	Suspected C2
Domain	stream / hyko.fif-lost[.]com	Open	20:22:45	DNS frame 72591	Suspected C2
Domain	second / gets / www.bert-hits[.]com	Open	20:23:03	DNS frame 72733	Suspected C2
IP	86.106.87.134	No domain seen yet	about 20:06:57	Victim sent about 4.8 MB over about 20 min	Suspected C2 or exfiltration
IP	62.3.53.87	No domain seen yet	about 20:22:17	Starts late in capture	Suspected later stage
IP	104.16.212.131	Open	about 20:06:47	36 MB downloaded in about 4 s	Check: payload or normal download
SHA256	Open	n/a	Open	Export Objects → HTTP	Open

Open questions: which IPs the C2 domains resolve to, and whether 86.106.87.134 and 62.3.53.87 were contacted without DNS.

Step 15: Attack timeline

The infection likely began at 20:05:55 UTC with a visit to quadcinema[.]com and moved to C2 traffic within about one minute. Times marked "about" are calculated from conversation start offsets and need checking against frame times.

Time (UTC)	Event	Evidence
20:05:55	Victim looks up quadcinema[.]com (likely compromised site)	DNS frame 1
20:05:56	Victim contacts aatthews[.]cfd, likely loading an injected script	DNS frame 41, TLS frame 53
about 20:06:36	Connection to logincrypt8338[.]com (172.67.214.168)	TLS frame 5224
about 20:06:47	36 MB downloaded from 104.16.212.131 in about 4 s	Conversations list
about 20:06:57	Long connection to 86.106.87.134 begins; about 4.8 MB sent out over about 20 min	Conversations list
Open	Connection to jaw.xos-aploq[.]com (104.21.34.58)	TLS frame 14279
20:18:59	Lookup of know.mom-nower[.]com	DNS frame 71423
20:19:08	Lookup of globalcert8618[.]net	DNS frame 71436
20:22:17	Lookups of comonto-rsr[.]com subdomains begin; connection to 62.3.53.87 starts about here	DNS frame 72431
20:22:45 – 20:24:42	Repeated lookups of fif-lost[.]com and bert-hits[.]com subdomains	DNS frames 72591–73225
20:26:41	Last lookup of know.mom-nower[.]com	DNS frame 73657

Open questions: what was downloaded, whether the 86.106.87.134 traffic is regular beaconing, and where winrun2915[.]com fits.

Step 16: Answer key comparison

Not compared yet: finish the analysis first, then open the exercise answers page and fill the last two columns.

Question	My finding	Answer key	Match?
Infected host IP	10.9.11.135		
Infected host MAC	Open		
Infected hostname	Open		
User account	gmcdowell		
Initial infection source	quadcinema[.]com → aatthews[.]cfd		
Malware family	Kongtuke chain (per exercise title); final payload open		
C2 servers	86.106.87.134, 62.3.53.87, C2 domains in Step 14		
Files and hashes	Open		

Lessons learned

- [ ] What I missed, and which filter or step would have caught it
- [ ] Which indicators were noise (normal traffic I flagged)
- [ ] What I would check first in the next case

Step 17: Detection rules

All 5 rules loaded in Suricata 7.0.3 with 0 failures, and all 5 fired on case01.pcap (102 alerts total). The rules use Snort-compatible syntax, so one file works in both Suricata and Snort. IOC rules (domains, IPs) are easy for attackers to change, so add a behavior rule once the payload download is confirmed.

```
alert udp $HOME_NET any -> any 53 (msg:"CASE01 - DNS query aatthews.cfd";
content:"|08|aatthews|03|cfd|00|"; nocase; sid:2000001; rev:1;)
alert tcp $HOME_NET any -> $EXTERNAL_NET 443 (msg:"CASE01 - TLS to
logincrypt8338.com"; flow:to_server,established;
content:"logincrypt8338.com"; nocase; sid:2000002; rev:1;)
alert udp $HOME_NET any -> any 53 (msg:"CASE01 - DNS query bert-hits.com";
content:"|09|bert-hits|03|com|00|"; nocase; sid:2000003; rev:1;)
alert ip $HOME_NET any -> 86.106.87.134 any (msg:"CASE01 - Traffic to
suspected C2 86.106.87.134"; sid:2000004; rev:1;)
alert ip $HOME_NET any -> 62.3.53.87 any (msg:"CASE01 - Traffic to suspected
C2 62.3.53.87"; sid:2000005; rev:1;)
```

Test command:

```
cd ~/netforensics
sudo suricata -r pcaps/case01.pcap -S rules/local.rules -l logs/ -k none
cat logs/fast.log
```

SID	Rule	Suricata 7.0.3 alerts	Snort 2 alerts	False positives on clean pcap	Notes
2000001	DNS aatthews.cfd	2	2	Open	Matches the 2 lookups in frames 41–42
2000002	TLS logincrypt8338.com	16	16	Open	Repeated encrypted connections
2000003	DNS bert-hits.com	3	3	Open	Matches second, gets, www subdomains
2000004	IP 86.106.87.134	73	3,764	Open	Snort count equals the 3,764 packets the victim sent; traffic is HTTP on port 80
2000005	IP 62.3.53.87	8	124	Open	Snort count equals the 124 packets the victim sent

Snort alerts on every matching packet; Suricata reported far fewer alerts for the IP rules, likely grouping by connection. Both tools detected all 5 rules.

Troubleshooting note: the first run missed the aatthews.cfd rule because a paste cut "alert" to "ert", so the rule failed to parse. Checking suricata.log for "rules successfully loaded" caught it.